Praca domowa zajęcia 2 – Damian Brzeziński

Analiza incydentu z zajęć, byłem w grupie 3 Incydent LastPass, z pracy w grupie udało nam się ustalić te rzeczy:
Nie wiadomo kto zaatakował, atakujący jest nie znany, dłga precyzyjna kampania sugeruje zaawansowanego aktora/APT.

Doszło do 2 incydentów:
1. (sierpień 2022): skompromitowano laptop firmowy inżyniera oprogramowania. Dało to dostęp do chmurowego środowiska deweloperskiego. Skradziono m.in. kod źródłowy dokumentację techniczną

2. Atakujący wykorzystał dane z incydentu 1, żeby wytypować cel, którym był starszy inżynier DevOps. Wykorzystał podatność w oprogramowaniu firm trzecich, wgrał malware i obszedł istniejące zabezpieczenia

Wektor wejścia to laptop firmowy i podatna aplikacja na komputerze inżyniera

Technika rozprzestrzeniania Z laptopa do chmurowego środowiska

Celem były kody źródłowe dokumentacja, sekrety API

Czas wykrycia pierwszy błędnie zamknięty i drugi kilka miesięcy po pierwszym włamaniu

Krótki opis: jako cyber kill chain na początku w 1 etapie doszło do identyfikacji inżynierów może **T1589** Gather Victim Identity Information z MITRE ATT&CK, następnie Przygotowanie malware/keylogger T1056.001, następnie dostarczenie, Exploitation to wykorzystanie podatności w oprogramowaniu firm trzecich, Instalacja złośliwego oprogramowania zdalna kontrola i dostęp do dokumentacji i kluczy.

Wpisz liczbę w DEC i odczytaj BIN i HEX

10 -> BIN: 1010 -> HEX:A

16 -> BIN: 10000 -> HEX:10

127 -> BIN: 111 1111 -> HEX: 7F

128 -> BIN: 1000 0000 -> HEX: 80

255 -> BIN: 1111 1111 -> HEX: ff

Wpisz w HEX i odczytaj w DEC

0x1F – BIN: 0001 1111 -> DEC: 31
0x41 – BIN: 100 0001-> DEC: 65

0x7F – BIN: 111 1111-> DEC: 127

Zdekoduj:

SGVsbG8= Hello

YWRtaW4= admin

cGFzc3dvcmQ= password

cG93ZXJzaGVsbCAtRW5jb2RIZENvbW1hbmQ= powershell -EncodedCommand

1. **Co znika po wyłączeniu zasilania: zawartość RAM czy dysku? Dlaczego to ważne przy incydencie?**

Zawartość RAM ponieważ RAM jest pamięcią ulotną. A jest to ważne, ponieważ ram pokazuje aktywność, której często nie widać na dysku dlatego analiza pamięci jest ważna podczas incident response .

2. **Ile to OxFF dziesiętnie i dlaczego dwa znaki hex to jeden bajt?**

0xFF jest to 240+15 czyli 255 dziesiętne , ponieważ jeden znak hex to 4 bity więc suma dwóch znaków to jeden bajt .

3. **Czy Base64 to szyfrowanie? Uzasadnij.**

Nie jest to szyfrowanie, jest to kodowanie ponieważ w każdej chwili można to zdekodować, jest to jedynie zmiana formatu zapisu. Można to zdekodować bez klucza.

4. **Co sprawdza SecureBoot, a czego pilnuje TPM?**

Secureboot sprawdza czy bootloader jest zaufany, sprawdza poprawność podpisu i czy podpis pasuje do zaufanych kluczy UEFI . Ogólnie pilnuje i sprawdza aby podczas startu uruchamiany był poprawny/zaufany kod.

A TPM pilnuje/chroni klucze i mierzy start - chroni klucze kryptograficzne i pomaga sprawdzić czy komputer uruchamia się w oczekiwanym stanie

5. **Dlaczego aplikacja nie może pisać bezpośrednio do sprzętu?**

Dzieje się tak ponieważ są granice zaufania. Aplikacja jest w userspace ring 3 natomiast sprzęt w ring 0 w kernelspace, aplikacja nie powinna mieć bezpośredniego dostępu do sprzętu. Dostępy przechodzą przez kontrolowane interfejsy. Pomiędzy nimi (user space i kernel space) jest syscall.

6. **Bonus: winword.exe uruchamia powershell.exe z -ExecutionPolicy Bypass. Co robisz?**

Powershell uruchomiony przez plik word z parametrem omijającym politykę wykonania wymaga analizy. Można sprawdzić pełną linie poleceń powershell, można również sprawdzić logi?

Krok 1 - Analiza procesów w czasie rzeczywistym

Nazwa	Nazwa pakietu	Identyfikator PID	Stan	Nazwa użytkownika	Użyc...	Zestaw roboczy (p...	Pamięć (akt...	Nazwa ścieżki obrazu	Arch...	Opis
Proces bezczynnoś...		0	Uruchomiony	SYSTEM	91	8 K	8 K			Procent czasu bezczynności procesora
Taskmgr.exe		26936	Uruchomiony	damia	03	212 648 K	110 052 K	C:\Windows\System32\Taskmgr.exe	x64	Menedżer zadań
dwm.exe		1804	Uruchomiony	DWM-1	01	148 496 K	88 612 K	C:\Windows\System32\dwm.exe	x64	Menedżer okien pulpitu
System		4	Uruchomiony	SYSTEM	01	7 640 K	12 K	C:\WINDOWS\system32\ntoskrnl.exe		NT Kernel & System
chrome.exe		16640	Uruchomiony	damia	00	286 124 K	100 124 K	C:\Program Files\Google\Chrome\Application\chrome...	x64	Google Chrome
svchost.exe		3096	Uruchomiony	USŁUGA SIECIOWA	00	11 580 K	2 024 K	C:\Windows\System32\svchost.exe	x64	Proces hosta dla usług systemu Windows

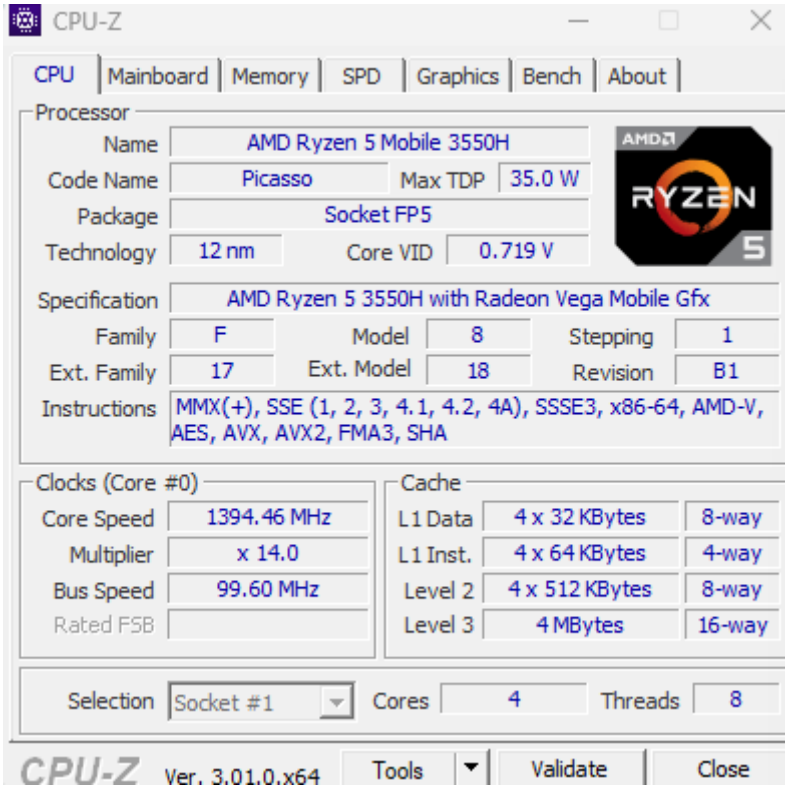
Uważam, że wygląda normalnie w wyszukiwarce spróbowałem znaleźć nietypowe procesy lub nietypowe lokalizację i nic takiego nie wykryłem (/tmp, AppData)
1 wiersz ma wysokie użycie CPU, które się stale zmieniało, jednak jest to proces bezczynności więc

uważam, że jest to norma i nie wymaga kontroli, w każdym z nich nazwy użytkowników, pamięć wydają się poprawne
Najwięcej CPU zużywa Task manager oraz chrome a pamięci Chrome i Slack

Nazwa	Nazwa pakietu	Identyfikator PID	Stan	Nazwa użytkownika	Użyc...	Zestaw roboczy (p...	Pamięć (akt...	Nazwa ścieżki obrazu
chrome.exe		14968	Uruchomiony	damia	00	410 472 K	311 376 K	C:\Program Files\Google\Chrome\Application\chrome...
chrome.exe		18212	Uruchomiony	damia	00	315 752 K	229 092 K	C:\Program Files\Google\Chrome\Application\chrome...
chrome.exe		14580	Uruchomiony	damia	00	304 032 K	212 688 K	C:\Program Files\Google\Chrome\Application\chrome...
Slack.exe	Slack	20488	Uruchomiony	damia	00	300 364 K	200 916 K	C:\Program Files\WindowsApps\com.tinyspeck.slackde...

Krok 2 Specyfikacja CPU

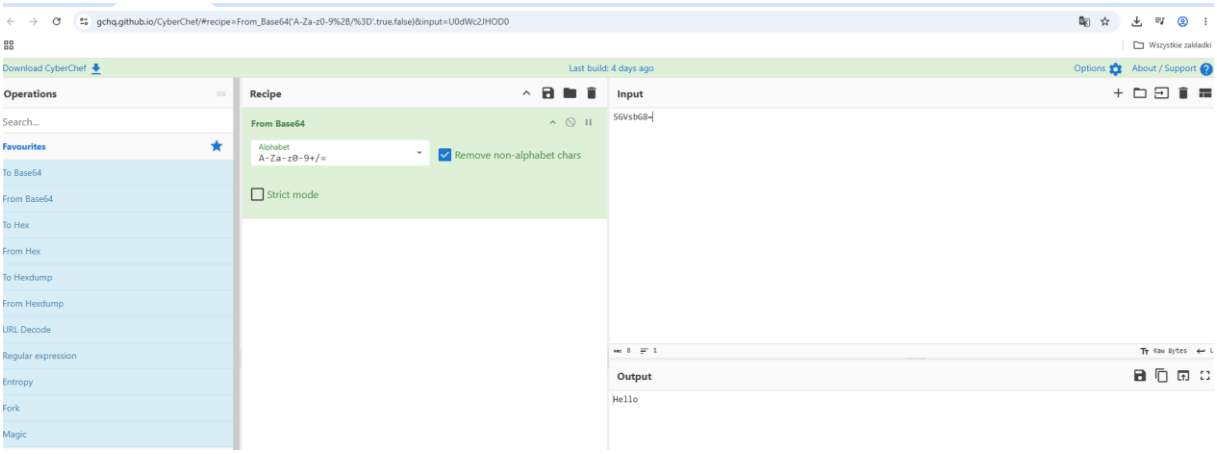
Model CPU: AMD RYZEN 5 3550H with Radeon Vega Mobile Gfx (8CPUs), ~ 2.1GHz
Architektura: AMD 64 Family 23 Model 24 Stepping 1 Authentic AMD
Rdzenie fizyczne: 4
Wątki logiczne: 8
Wirtualizacja włączona: tak
Wybrane flagi CPU: MMX(+), SSE(1,2,3,4.1,4.2,4A), SSSE3, AMD-V, AES, AVX SHA



Krok 3 Reprezentacja danych w praktyce

Wykonane zgodnie z instrukcją na Slacku powyżej wybrane przykłady.

Wykorzystanie Cyberchef do odczytu



Krok 4 i 5 Boot i hierarchia procesów

Tryb systemu BIOS	UEFI
Producent płyty głównej	ASUSTeK COMPUTER INC.
Produkt płyty głównej	FX705DY
Wersja płyty głównej	1.0
Rola platformy	Urządzenie przenośne
Stan bezpiecznego rozruchu	Włączone

Process Explorer - Sysinternals: www.sysinternals.com [DAMIAN_HOUSE\damia]

File Options View Process Find Users Help

Process	CPU	Private Bytes	Working Set	PID	Description	Company Name
Registry		6 408 K	59 620 K	176		
System Idle Process	81.67	60 K	8 K	0		
System	2.97	68 K	8 228 K	4		
Interrupts	0.37	0 K	0 K	n/a	Hardware Interrupts and DPCs	
smss.exe		1 160 K	1 516 K	720		
Memory Compression	0.19	2 304 K	660 516 K	3500		
csrss.exe	< 0.01	2 368 K	7 796 K	900		
wininit.exe		1 704 K	9 808 K	1232		
services.exe		6 320 K	12 292 K	1376		
svchost.exe	0.19	13 896 K	42 532 K	1528	Proces hosta dla usług syste...	Microsoft Corporation
SearchHost.exe		53 488 K	129 192 K	11764		Microsoft Corporation
msedgewebview2....		39 896 K	120 944 K	12636	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		2 860 K	11 772 K	12852	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		12 232 K	41 020 K	15252	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		45 220 K	62 992 K	15260	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		7 520 K	19 572 K	15292	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		103 852 K	126 972 K	15320	Microsoft Edge WebView2	Microsoft Corporation
StartMenuExperience...	< 0.01	101 044 K	168 064 K	11788	Windows Start Experience H...	Microsoft Corporation
WidgetBoard.exe		5 220 K	32 604 K	11920		Microsoft Corporation
RuntimeBroker.exe		14 988 K	65 304 K	12004	Runtime Broker	Microsoft Corporation
UserOOBEBroker.exe		2 100 K	11 512 K	12284	User OOBE Broker	Microsoft Corporation
WidgetService.exe		5 416 K	25 224 K	12320	WidgetService.exe	Microsoft Corporation
WhatsApp.Root.exe	< 0.01	88 308 K	227 476 K	14148	WhatsApp.Root	WhatsApp.Root
msedgewebview2....	< 0.01	58 216 K	91 432 K	8572	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		2 812 K	12 284 K	10852	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		142 812 K	43 784 K	19712	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		13 604 K	25 996 K	14716	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		7 992 K	6 720 K	10304	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		232 792 K	129 936 K	12108	Microsoft Edge WebView2	Microsoft Corporation
msedgewebvie...		7 852 K	23 724 K	23976	Microsoft Edge WebView2	Microsoft Corporation
MicrosoftStartFeedPro...		10 752 K	42 100 K	10612		Microsoft Corporation
RuntimeBroker.exe		2 484 K	14 332 K	15808	Runtime Broker	Microsoft Corporation
ShellExperienceHost....	Susp...	21 620 K	89 012 K	16176	Windows Shell Experience H...	Microsoft Corporation
RuntimeBroker.exe		4 204 K	31 320 K	15512	Runtime Broker	Microsoft Corporation
RuntimeBroker.exe		2 496 K	14 736 K	15468	Runtime Broker	Microsoft Corporation
mcafee-security.exe		31 676 K	23 892 K	17292	McAfee® Personal Security	McAfee LLC
RuntimeBroker.exe		3 444 K	26 284 K	12148	Runtime Broker	Microsoft Corporation
ApplicationFrameHost...		11 560 K	47 676 K	22208	Application Frame Host	Microsoft Corporation
dllhost.exe		2 084 K	12 304 K	9976	COM Surrogate	Microsoft Corporation
CrossDeviceService.e...		23 988 K	81 796 K	24640	Microsoft Cross Device Servi...	Microsoft Corporation
RuntimeBroker.exe		2 480 K	14 196 K	19268	Runtime Broker	Microsoft Corporation
LockApp.exe	Susp...	20 092 K	70 476 K	12124	LockApp.exe	Microsoft Corporation